

CYBER SECURITY– TASK 4

PASSWORD SECURITY ANALYSIS

1. INTRODUCTION

Passwords are one of the most commonly used methods of authentication for accessing computers, applications, websites, networks, and organizational systems. A password helps verify that a user is authorized to access a particular account or service.

Weak or reused passwords can make accounts vulnerable to attacks such as brute-force attacks, password spraying, credential stuffing, and phishing. Therefore, organizations need to establish proper password security guidelines and encourage users to follow strong authentication practices.

A secure password policy should focus on password length, uniqueness, secure storage, password managers, multi-factor authentication (MFA), and protection against common password attacks.

2. OBJECTIVE

The main objective of this task is to understand strong authentication practices and develop an organizational password security policy.

Specific Objectives

1. Understand the characteristics of a strong password.
 2. Identify risks associated with weak and reused passwords.
 3. Understand the importance of password uniqueness.
 4. Learn how password managers improve password security.
 5. Understand the role of Multi-Factor Authentication.
 6. Develop password security guidelines for an organization.
 7. Learn methods to protect user accounts against password-based attacks.
-

3. PASSWORD SECURITY PRINCIPLES

3.1 Password Length

Password length is one of the most important factors in password security.

Longer passwords generally provide greater resistance against guessing and brute-force attacks.

Users should prefer long passwords or passphrases rather than short passwords with predictable patterns.

Example of a weak password:

Password123

Example of a stronger passphrase:

River-Coffee-Moon-Window-27

The second example is longer and more difficult to guess.

3.2 Password Uniqueness

Every important account should have a unique password.

Users should not use the same password for multiple accounts because if one website suffers a data breach, attackers may try the stolen username and password combination on other services.

For example:

- Email → Unique password
- Banking → Different unique password
- Social media → Different unique password
- College account → Different unique password

Using unique passwords limits the damage if one password is compromised.

3.3 Avoid Common Passwords

Users should avoid easily guessed passwords such as:

- 123456
- password
- qwerty
- admin
- welcome
- Password123

Users should also avoid passwords based on easily available personal information such as names, birthdays, phone numbers, or organization names.

3.4 Avoid Password Reuse

Password reuse occurs when the same password is used for multiple accounts.

This creates a significant security risk because attackers can use credentials obtained from one compromised service to attempt access to other services.

Example:

If the same password is used for both an email account and a shopping website, a breach of the shopping website could put the email account at risk.

3.5 Use Passphrases

A passphrase consists of multiple words and can be easier to remember while still providing significant length.

Example:

Cloud-River-Orange-Window-Train

Users should avoid using well-known quotations or predictable phrases.

4. PASSWORD MANAGERS

A password manager is a software application that securely stores and manages passwords.

It can help users generate strong and unique passwords for different accounts without requiring them to memorize every password.

Advantages of Password Managers

1. Generate strong passwords.
2. Store unique passwords for different accounts.
3. Reduce password reuse.
4. Help users manage many accounts.
5. Make it easier to use long and complex passwords.
6. Reduce the need to write passwords down.
7. Some password managers can identify weak or reused passwords.

Organizational Guideline

Employees should use an organization-approved password manager where available rather than storing passwords in plain text files, spreadsheets, notes, or unsecured documents.

5. MULTI-FACTOR AUTHENTICATION (MFA)

Multi-Factor Authentication is an authentication method that requires users to provide more than one type of authentication factor before gaining access to an account.

Common Authentication Factors

1. Something you know

Examples:

- Password

- PIN

2. Something you have

Examples:

- Mobile phone
- Security key
- Authentication device

3. Something you are

Examples:

- Fingerprint
- Facial recognition
- Other biometric characteristics

Example

When logging into an account, a user may enter:

Step 1: Username and password

Step 2: Verification code or approval through an authentication application

Even if an attacker obtains the password, the second factor can provide an additional barrier to unauthorized access.

6. COMMON PASSWORD ATTACKS

6.1 Brute-Force Attack

A brute-force attack involves trying many possible password combinations until the correct password is discovered.

Prevention

- Use long passwords.
- Use account lockout or rate limiting where appropriate.
- Enable MFA.
- Monitor repeated failed login attempts.

6.2 Dictionary Attack

A dictionary attack attempts passwords from a list of commonly used words and passwords.

Prevention

- Avoid common words and predictable passwords.

- Use long passphrases.
 - Use unique passwords.
 - Use MFA.
-

6.3 Credential Stuffing

Credential stuffing occurs when attackers use username-password combinations obtained from a previous data breach to attempt access to other services.

Prevention

- Never reuse passwords.
 - Use unique passwords for important accounts.
 - Enable MFA.
 - Monitor for suspicious login activity.
-

6.4 Password Spraying

Password spraying involves trying a small number of commonly used passwords against many accounts rather than repeatedly attacking one account.

Prevention

- Block commonly used passwords.
 - Use MFA.
 - Monitor authentication logs.
 - Apply rate limiting and appropriate authentication controls.
-

6.5 Phishing

Attackers may use fake emails, messages, or websites to trick users into revealing their passwords.

Prevention

- Verify login pages.
 - Avoid suspicious links.
 - Check the sender.
 - Use MFA.
 - Report suspicious messages.
-

7. ORGANIZATIONAL PASSWORD SECURITY POLICY

7.1 Purpose

The purpose of this password security policy is to establish guidelines for creating, storing, managing, and protecting passwords used within an organization.

The policy aims to reduce unauthorized access and protect organizational systems, applications, and sensitive information.

7.2 Scope

This policy applies to:

- Employees
- Interns
- Contractors
- Administrators
- Other authorized users

It applies to organizational:

- Computers
 - Applications
 - Email accounts
 - Networks
 - Cloud services
 - Databases
 - Business systems
-

8. PASSWORD POLICY GUIDELINES

1. Password Length

Users should create passwords that are sufficiently long. Long passphrases should be preferred over short and predictable passwords.

2. Password Uniqueness

Passwords must be unique for different important organizational accounts.

3. No Password Sharing

Users must never share their passwords with colleagues, friends, or other individuals.

IT or security personnel should not ask users to disclose their passwords.

4. No Plain-Text Storage

Passwords must not be stored in:

- Text files
- Spreadsheets
- Sticky notes
- Unsecured documents
- Email messages
- Chat messages

5. Use Approved Password Managers

Where available, employees should use an organization-approved password manager for securely managing passwords.

6. Enable MFA

MFA should be enabled for important organizational systems, especially accounts that provide access to sensitive information or administrative functions.

7. Avoid Common Passwords

Users must not use commonly known or easily guessed passwords.

8. Avoid Personal Information

Passwords should not be based on information that can easily be associated with the user, such as:

- Name
- Birthday
- Phone number
- Address
- Company name
- Family names

9. Do Not Reuse Compromised Passwords

A password known or suspected to have been exposed in a breach must not be reused.

10. Protect Authentication Information

Users should protect passwords, MFA codes, recovery codes, and security keys from unauthorized access.

11. Report Compromised Credentials

Users must immediately report suspected password theft or unauthorized account activity to the organization's IT or security team.

12. Secure Recovery Methods

Account recovery methods should also be protected because attackers may attempt to use recovery mechanisms to bypass normal authentication.

9. PASSWORD CREATION GUIDELINES

Employees should follow these practices when creating passwords:

DO

- Use long passwords or passphrases.
- Use unique passwords.
- Use a password manager.
- Enable MFA.
- Use random passwords for important accounts.
- Change a password when compromise is suspected.
- Protect recovery codes and authentication devices.

DO NOT

- Use 123456.
 - Use password.
 - Use your name or birthday.
 - Reuse passwords.
 - Share passwords.
 - Store passwords in plain-text documents.
 - Use predictable patterns.
 - Enter passwords on suspicious websites.
-

10. PASSWORD SECURITY POLICY TABLE

Security Requirement	Organizational Guideline
Password Length	Use sufficiently long passwords or passphrases
Uniqueness	Use a different password for each important account
Common Passwords	Do not use commonly known passwords
Personal Information	Do not use easily available personal information
Password Sharing	Passwords must never be shared
Password Manager	Use an organization-approved password manager
MFA	Enable MFA for important systems and accounts
Password Storage	Do not store passwords in plain text
Compromised Password	Change/report the password immediately
Recovery Information	Protect recovery codes and authentication methods
Phishing	Never enter passwords into suspicious websites
Monitoring	Monitor suspicious login attempts and account activity

11. PASSWORD SECURITY BEST PRACTICES FOR ORGANIZATIONS

Organizations should implement multiple layers of authentication security rather than depending only on passwords.

1. Use MFA

MFA should be enabled for critical accounts and systems.

2. Use Strong Authentication

Organizations should use secure authentication mechanisms and avoid outdated or insecure authentication methods.

3. Protect Password Databases

Passwords should not be stored in plain text. Systems should use appropriate password hashing and secure authentication mechanisms.

4. Block Known Compromised Passwords

Organizations should prevent users from selecting passwords known to have appeared in previous breaches where practical.

5. Monitor Login Activity

Organizations should monitor authentication logs for suspicious activities such as repeated failed login attempts or unusual login locations.

6. Apply Least Privilege

Users should receive only the access required to perform their responsibilities.

7. Educate Employees

Employees should receive regular security awareness training covering phishing, password protection, MFA, and social engineering.

8. Have an Incident Response Process

Organizations should have procedures for responding to compromised accounts and stolen credentials.

12. EXAMPLE OF A SECURE AUTHENTICATION PROCESS

A secure organizational login process can work as follows:

Step 1:

User enters their username.

↓

Step 2:

User enters their password.

↓

Step 3:

The system verifies the credentials.

↓

Step 4:

The system requests an additional authentication factor.

↓

Step 5:

User provides the MFA verification.

↓

Step 6:

The system grants access if all authentication requirements are successfully verified.

This approach provides stronger protection than relying only on a password.

13. CONCLUSION

Password security is an essential component of cybersecurity because passwords are frequently targeted by attackers. Weak, predictable, and reused passwords can lead to unauthorized access, data theft, financial loss, and account compromise.

A strong organizational password policy should emphasize long and unique passwords, password managers, MFA, secure password handling, protection against phishing, and monitoring of suspicious authentication activity.

Users should understand that password security is not only about creating a complex password. It also involves using unique credentials, protecting authentication information, enabling MFA, and responding quickly when credentials are compromised.

By implementing these practices, organizations can significantly strengthen their authentication security and reduce the risk of password-based cyber attacks.